PRADITA University

IT40813 · IT Governance, Risk & Compliance

Keamanan Informasi ISO/IEC 27001 dan NIST CSF

Pertemuan 06

Alfa Yohannis



Isi Pertemuan

PRADITA University

1. Tujuan dan Konteks
2. Tiga Tujuan Pelindungan
3. Sistem Manajemen
4. Annex A dan SoA
5. Enam Fungsi CSF
6. Profil dan Tier
7. Celah Kontrol
8. Aktivitas, Ringkasan, dan Latihan

Kebijakan sudah ditandatangani. Mengapa 12 dari 120 akun masih luput?

Tujuan Pembelajaran

PRADITA University

- Menjelaskan struktur ISMS (*Information Security Management System*) menurut ISO/IEC 27001:2022 serta peran kontrol Annex A dan ISO/IEC 27002.
- Menyusun profil saat ini NIST CSF 2.0 untuk sebuah organisasi.
- Menganalisis celah kontrol keamanan dan mengaitkannya dengan skenario di *risk register*.

Masalah: Kebijakan Ada, Akses Tetap Lemah

PRADITA University

- Pengandaian bab sebelumnya: 6 dari 30 akun sampel masih aktif setelah penugasan berakhir.
- Peninjauan berikutnya mencabut 24 dari 120 akun. Daftar peninjau hanya memuat 108 akun, sehingga 12 akun luput.
- Lima rumah sakit menjalankan SIMRS dengan versi berbeda. Bukti satu lokasi tidak mewakili seluruh Medikara.
- Kebijakan menunjukkan niat. Hasil peninjauan membuktikan pelaksanaan.
- Hasil kerja: profil saat ini dan daftar celah untuk tonggak C2.

Diagram Konsep Bab 6

PRADITA University

ISMS menghubungkan risiko, kontrol, dan hasil keamanan



NIST CSF: Govern, Identify, Protect, Detect, Respond, Recover bekerja bersamaan. Pemetaan tidak membuktikan kesetaraan kerangka.

Kerahasiaan, Integritas, dan Ketersediaan

Tujuan	Pertanyaan	Bukti contoh	Risiko
Kerahasiaan	Apakah vendor hanya melihat data penugasannya?	Persetujuan dan pembatasan akses	R-01
Integritas	Siapa mengubah alergi dan kapan?	Jejak perubahan yang terlindungi	R-02
Ketersediaan	Apakah data dapat dibaca saat gangguan?	Hasil uji pemulihan dan akses darurat	R-05

Analogi lemari obat: lemari terkunci mengurangi akses tidak sah, pencatatan keluar masuk menjaga ketepatan stok, dan kunci cadangan menjaga layanan. Konflik antartujuan diselesaikan sesuai konteks layanan.

Dua Contoh: Bukan Hanya Kerahasiaan

PRADITA University

- Misalkan satu akun bersama dipakai 12 petugas sebuah bangsal.
- Dalam sebulan tercatat 40 perubahan riwayat alergi, dan tidak satu pun dapat ditelusuri kepada petugas tertentu. Kelemahannya integritas, R-02.
- Misalkan semua akses darurat diblokir saat pengelola identitas terganggu 2 jam.
- Data terlindung, tetapi gangguan 2 jam menyentuh sekitar 548 kunjungan.
- Akses darurat yang terbatas, beralasan, dan ditinjau perlu diuji.

Membaca Penelitian: WannaCry pada NHS

PRADITA University

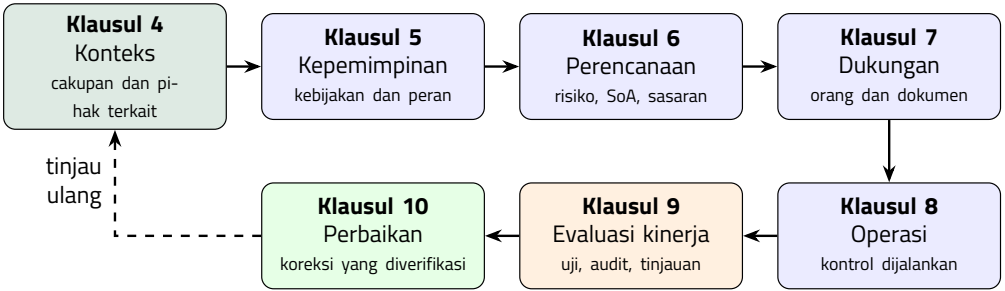
- Ghafur dan rekan (2019) menelaah serangan 2017 dengan data episode rumah sakit.
- 34 *trust* terinfeksi; sekitar 13.500 janji rawat jalan dibatalkan pada pekan serangan.
- Pendaftaran gawat darurat turun sekitar 4 persen, elektif sekitar 9 persen, per hari per rumah sakit.
- Kerugian kegiatan £5,9 juta. Kematian tidak naik, tetapi disebut ukuran kasar bahaya bagi pasien.
- Angka ini tidak disalin ke Medikara. Yang dipelajari adalah cara mengukurnya.

ISMS: Sistem, Bukan Daftar Alat

PRADITA University

- ISMS menghubungkan kebijakan, risiko, pelaksanaan, evaluasi, dan perbaikan.
- ISO/IEC 27001 menetapkan persyaratannya pada klausul 4 sampai 10.
- Analogi dapur: cairan pembersih belum memastikan dapur bersih. Jadwal, pelaksana, pemeriksaan, dan peninjauan membentuk sistem.
- Amandemen 1:2024 hanya mengubah 4.1 dan 4.2: apakah perubahan iklim isu yang relevan.
- Naskah ISO berbayar. Rincian klausul perlu dicocokkan ke naskah berlisensi.

Klausul 4 sampai 10 sebagai Satu Sistem



Ringkasan pembelajaran, bukan reproduksi isi standar. SoA adalah *Statement of Applicability*.

Klausul pada Kontrol AC-01 (Misalkan)

Klausul	Pertanyaan	Bukti pada AC-01
4 Konteks	Sistem, lokasi, dan pihak mana yang masuk cakupan?	5 rumah sakit, Medikara+, 120 akun; K-01
5 Kepemimpinan	Siapa menetapkan kebijakan dan peran?	Kebijakan akses; direksi menerima risiko sisa R-01
6 Perencanaan	Risiko dan kontrol apa yang dipilih?	R-01 skor $3 \times 4 = 12$; baris SoA; nol akun tanpa pemilik
7 Dukungan	Apakah orang dan dokumen cukup?	Peninjau ditunjuk; prosedur tertulis
8 Operasi	Apakah kontrol dijalankan?	Daftar akun, penandaan, tiket pencabutan
9 Evaluasi kinerja	Apakah kontrol bekerja?	108 dari 120 akun; audit 6 dari 30; tinjauan pimpinan
10 Perbaikan	Apa yang berubah karena temuan?	Prosedur keluar vendor diubah; diuji ulang

Dua Contoh: Kegiatan dan Sistem

PRADITA University

- Misalkan alat pemantauan menghasilkan 300 alarm per bulan pada tiap 5 rumah sakit, total 1.500.
- Dengan 10 menit per alarm, kerjanya 250 jam per bulan, lebih dari satu orang penuh waktu.
- Misalkan AC-01 bulan pertama mencabut 24 dari 120 akun. Sebabnya: tanggal berakhir penugasan tidak masuk daftar.
- Setelah prosedur diubah, pencabutan turun menjadi 9, 5, dan 2 akun, atau sekitar 92 persen.
- Temuan 12 akun tidak selesai hanya dengan mencabut 12 akun.

Sertifikat dan Ruang Lingkup

PRADITA University

- Misalkan sertifikat hanya untuk pusat data: 36 fasilitas layanan berada di luar lingkupnya.
- Misalkan sertifikat vendor berlaku 14 bulan, tetapi lingkupnya hanya pengembangan aplikasi. Akun dukungan tidak tercakup.
- Periksa tanggal, penerbit, ruang lingkup, dan temuan.
- Culot dan rekan (2021) mengelompokkan penelitian ke lima fokus: standar lain, motivasi, masalah penerapan, hasil, dan konteks.
- Pakai lima fokus itu sebagai daftar pertanyaan atas klaim “sudah bersertifikat”.

Annex A: 93 Kontrol dalam Empat Tema

PRADITA University

Nomor	Tema	Jumlah	Contoh topik pada Medikara
5	Organisasi	37	5.18 hak akses; 5.19 dan 5.20 pemasok; 5.26 tanggapan insiden
6	Manusia	8	Pelatihan petugas; tanggung jawab setelah penugasan berakhir
7	Fisik	14	Ruang server dan perangkat di 36 fasilitas
8	Teknologi	34	8.5 autentikasi; 8.13 cadangan; 8.15 pencatatan; 8.16 pemantauan
Total		93	

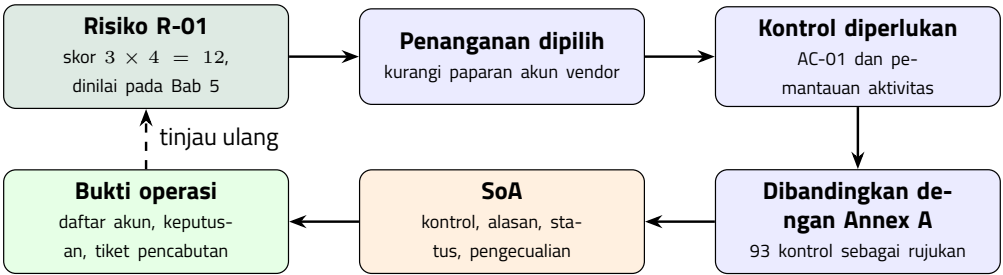
Annex A dipakai untuk memeriksa bahwa tidak ada kontrol perlu yang terlewat, bukan sebagai daftar yang otomatis wajib. Uraian topik bukan terjemahan resmi.

Persyaratan dan Panduan

Standar	Sifat	Pemakaian pada Medikara
ISO/IEC 27001:2022	Persyaratan sistem manajemen	Menilai ruang lingkup ISMS, SoA, evaluasi, dan perbaikan
ISO/IEC 27002:2022	Panduan penerapan kontrol	Cara merancang peninjauan hak akses pada AC-01
ISO 27799:2025	Panduan kontrol untuk organisasi kesehatan	Rekam medis elektronik, perangkat digital fasilitas, telekonsultasi Medikara+

Sertifikasi mengacu pada persyaratan, bukan panduan. Pembatasan akses tidak boleh merusak kebutuhan pelayanan darurat. Bab 5 membatasi pengecualian darurat akun vendor paling lama 24 jam.

Dari Risiko ke SoA



SoA memuat kontrol yang diperlukan, alasan, status penerapan, dan alasan pengecualian. Analogi perjalanan: perlengkapan yang tidak dibawa tetap dinilai terhadap tujuan.

Penalaran SoA

Kontrol	Alasan	Status dan bukti
AC-01 peninjauan hak akses (5.18)	Akses vendor berlebih pada R-01; K-01	Sebagian; bukti 1 dari 5 rumah sakit
Pencatatan aktivitas (8.15)	Menelusuri perubahan data pada R-01, R-02	Catatan ada; tinjauan belum terbukti
Cadangan dan pemulihan (8.13)	Menjaga data saat gangguan pada R-05; K-02	Cadangan ada; uji pemulihan diminta
Pengembangan alih daya (8.30)	Vendor mengubah Medikara+; R-07	Usulan pengecualian ditolak

Kode sering tertukar: AC-01 adalah kode lokal Medikara, 5.18 nomor Annex A, dan AC-01 pada berkas NIST milik SP 800-53. Tulis selalu sumber kodenya.

Kasus Medikara: SoA untuk Cakupan Terbatas

PRADITA University

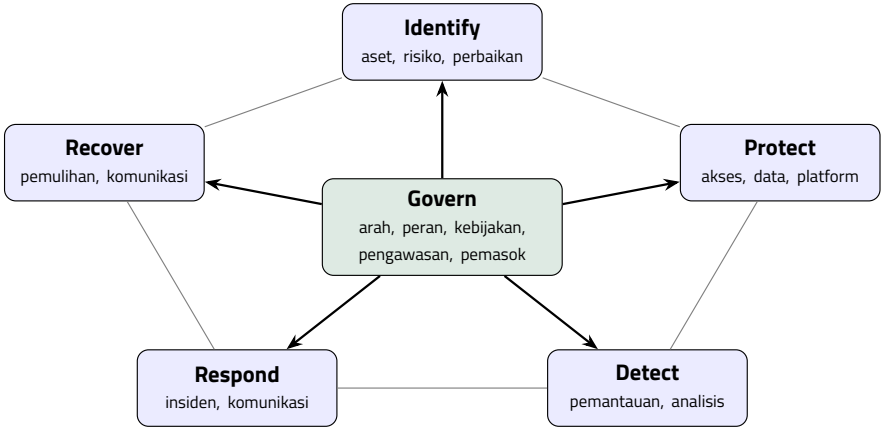
- Misalkan 93 kontrol dinilai untuk 5 rumah sakit dan Medikara+.
- Hasil awal: 84 diperlukan dan 9 diusulkan dikecualikan, sekitar 9,7 persen.
- Tiga usulan ditolak karena R-07 menunjukkan vendor tetap mengubah Medikara+.
- Hasil akhir: 87 diperlukan dan 6 dikecualikan, dengan alasan, penyetuju, dan tanggal tinjau ulang.
- Jumlah kontrol bukan ukuran keamanan. Kualitas alasannya yang dinilai.

Struktur Inti NIST CSF 2.0

PRADITA University

- Hierarki hasil: 6 fungsi, 22 kategori, dan 106 subkategori.
- Hasil itu bukan daftar periksa tindakan, dan urutannya bukan urutan kerja.
- CSF menjelaskan hasil yang diinginkan tanpa menetapkan cara mencapainya.
- Analogi gedung: pintu yang kuat tidak menggantikan petugas dan rencana penanganan.
- Layanan API dan cloud masuk cakupan profil. Rinciannya pada IT40613 dan IT40713.

Govern Mengarahkan Lima Fungsi Lain



Hasil dan Pertanyaan pada Enam Fungsi

PRADITA University

Fungsi	Hasil (ringkasan)	Pertanyaan Medikara	Bukti contoh
Govern	Strategi, harapan, dan kebijakan risiko ditetapkan serta dipantau	Siapa menerima risiko akses vendor?	Keputusan dan wewenang
Identify	Risiko keamanan saat ini dipahami	Sistem dan data apa yang terlibat?	Inventaris, alur data
Protect	Pengaman dipakai untuk mengelola risiko	Bagaimana akses dibatasi?	Daftar hak, bukti AC-01
Detect	Kemungkinan serangan ditemukan dan dianalisis	Bagaimana akses menyimpang diketahui?	Catatan alarm dan tinjauan
Respond	Tindakan atas insiden yang terdeteksi diambil	Siapa membekukan akses?	Prosedur, hasil latihan
Recover	Aset dan operasi yang terdampak dipulihkan	Bagaimana data dipulihkan?	Hasil uji pemulihan

Dua Contoh: Fungsi Saling Melengkapi

PRADITA University

- Misalkan seluruh 108 akun pada daftar peninjau memakai MFA. Cakupannya tampak 100 persen.
- Terhadap populasi 120 akun, cakupannya hanya 90 persen. Protect tidak menolong bila Identify belum lengkap.
- Misalkan alarm akses diterima dalam 5 menit, tetapi tidak ada yang berwenang membekukan akun.
- Data latihan Bab 1: akun dukungan memanggil data 8 malam dan baru diketahui pada hari ke-11.
- Kecepatan deteksi belum menghasilkan penanganan.

Mengapa Govern Ditambahkan

PRADITA University

Subkategori	Hasil (ringkasan)	Hasil kerja Medikara
GV.OC-03	Persyaratan hukum, regulasi, dan kontrak dipahami serta dikelola	Register K-01 sampai K-16, Bab 3
GV.RM-02	Pernyataan *risk appetite* dan *risk tolerance* ditetapkan	Nol akun vendor aktif tanpa pemilik, Bab 5
GV.RR-02	Peran, tanggung jawab, dan wewenang ditegakkan	Hak keputusan akses vendor, Bab 2
GV.SC-07	Risiko pemasok dipahami dan dipantau sepanjang hubungan	Vendor Medikara+, R-01, insiden 2025

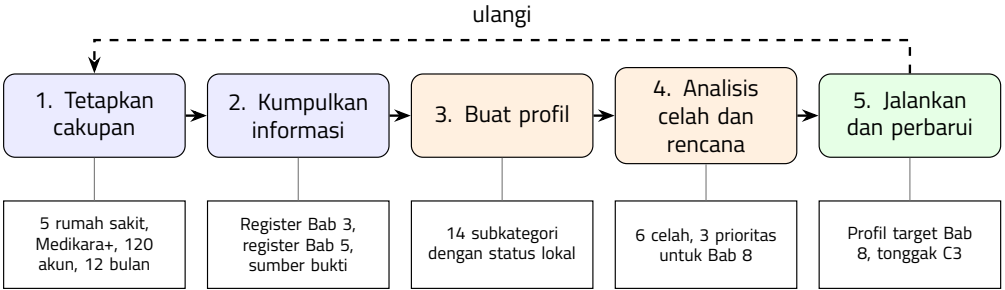
Versi 1.1 punya lima fungsi. Versi 2.0 menambahkan Govern dan menonjolkan tata kelola serta rantai pasok. Tanpa Govern, penilaian mudah berhenti sebagai urusan tim teknis (penafsiran bab).

ISO/IEC 27001 dan NIST CSF

Pembeda	ISO/IEC 27001:2022	NIST CSF 2.0
Sifat	Persyaratan sistem manajemen	Taksonomi hasil, tanpa menetapkan cara
Unsur	Klausul 4 sampai 10, 93 kontrol Annex A, SoA	6 fungsi, 22 kategori, 106 subkategori, profil, *tier*
Pemeriksaan	Dapat disertifikasi dalam ruang lingkup	Tidak ada skema sertifikasi pada naskah 2.0
Akses naskah	Berbayar	Terbuka
Luaran Medikara	Ruang lingkup ISMS, SoA, hasil evaluasi	Profil saat ini, celah, profil target Bab 8

Keduanya melengkapi, bukan menggantikan.

Lima Langkah Profil



Profil saat ini menyebut hasil yang sedang dicapai dan seberapa jauh. Bab 6 mengerjakan langkah 1 sampai 4. Profil target dirancang pada Bab 8.

Status Lokal dan Batas Bukti

Status lokal	Arti	Tindakan
Terbukti	Bukti sesuai cakupan dan periode	Simpan sumber dan peninjau
Sebagian	Sebagian hasil atau lokasi belum tercakup	Jelaskan celah spesifik
Belum ada bukti	Klaim belum dapat diuji	Minta bukti; jangan beri status lulus
Tidak relevan	Ada alasan terhadap cakupan	Catat persetujuan dan tinjau ulang

Audit: 24 dari 30 akun sesuai, atau 80 persen. Kesimpulannya ada 6 pengecualian dalam sampel, bukan 80 persen aman. Misalkan 150 cadangan berhasil dalam 30 hari pada 5 rumah sakit: pemulihan belum terbukti sebelum diuji.

Profil: Govern dan Identify (Misalkan)

PRADITA University

Subkategori	Status	Bukti dan batasnya	Tautan
GV.OC-03	Sebagian	Register 16 baris; 7 baris belum diverifikasi	K-01 sampai K-16
GV.RM-02	Sebagian	Batas nol akun sudah dirumuskan; pemantauan belum teruji	R-01
GV.RR-02	Sebagian	Hak keputusan tertulis; 12 akun belum punya pemilik	R-01
GV.SC-07	Sebagian	Tinjauan berkala belum ada; laporan insiden telat	R-01, R-08, K-05
ID.AM-02	Sebagian	Daftar lokal 5 rumah sakit belum direkonsiliasi	R-02

Profil: Protect sampai Recover (Misalkan)

PRADITA University

Subkategori	Status	Bukti dan batasnya	Tautan
PR.AA-01	Sebagian	Akun bersama ditemukan	R-02, K-01
PR.AA-03	Sebagian	MFA pada 108 akun; 12 tidak diketahui	R-01, K-01
PR.AA-05	Sebagian	Bukti AC-01 pada 1 dari 5 rumah sakit	R-01, R-02, K-01
PR.AA-06	Tidak relevan	Vendor jarak jauh; tinjau bila hadir di lokasi	Tidak ada
PR.PS-04	Terbukti	Catatan pada 5 SIMRS selama 12 bulan	R-01
PR.DS-11	Sebagian	Cadangan malam berjalan; uji belum ada	R-05, K-02
DE.CM-03	Sebagian	Catatan ada; tinjauan belum ada	R-01, K-01
RS.MA-01	Belum ada bukti	Prosedur belum dilatih bersama vendor	R-01, R-12, K-04, K-05
RC.RP-03	Belum ada bukti	Hasil verifikasi belum tersedia	R-05, K-02

14 dari 106 subkategori: 1 terbukti, 10 sebagian, 2 belum ada bukti, 1 tidak relevan.

Tier Bukan Rata-Rata

Tier	Tata kelola risiko (ringkasan)	Risiko pemasok (ringkasan)
Tier 1, Partial	Strategi risiko diterapkan seadanya	Umumnya tidak menyadari risiko pemasok
Tier 2, Risk Informed	Disetujui manajemen, mungkin belum menjadi kebijakan organisasi	Sadar, tetapi belum bertindak konsisten atau formal
Tier 3, Repeatable	Disetujui resmi sebagai kebijakan, diperbarui berkala	Perjanjian tertulis dan pemantauan
Tier 4, Adaptive	Dipantau pimpinan bersama risiko keuangan dan risiko lain	Informasi hampir waktu nyata

Pimpinan memilih *tier* per organisasi, fungsi, atau kategori. Rumus nilai 4, 2, dan 1 yang menghasilkan rata-rata 2,0 tidak berdasar. Status lokal, *tier*, dan kapabilitas COBIT tidak saling dikonversi.

Pemetaan Menunjukkan Kontribusi

- Hubungan subkategori, kontrol, risiko, dan kewajiban dapat banyak ke banyak.
- NIST SP 1347: NIST tidak menguji kebenaran pemetaan dari pihak lain.
- Berkas NIST memuat dua daftar untuk PR.AA-05: 11 kontrol dan 6 kontrol, irisannya 5.
- Misalkan AC-01 hanya punya 12 dari 60 catatan bulanan, atau 20 persen: celah cakupan.
- Misalkan 0 dari 260 catatan tinjauan mingguan tersedia: celah deteksi dan tindak lanjut.

Pemetaan Subkategori ke Annex A

PRADITA University

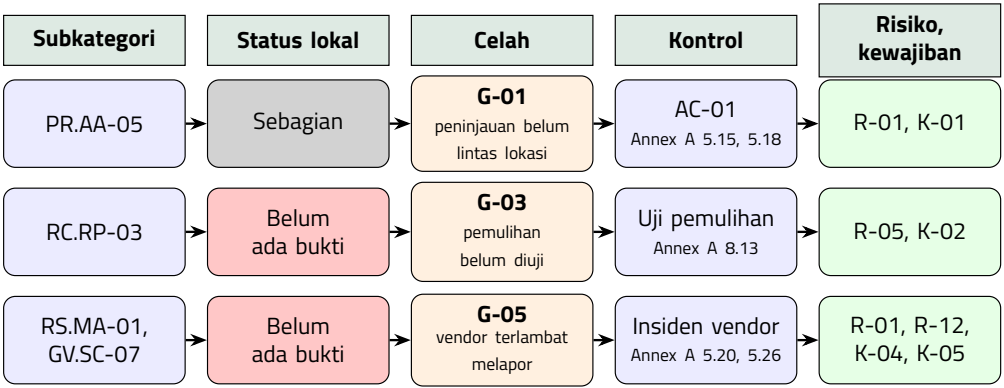
Subkategori	Annex A	Kontrol Medikara	Risiko, kewajiban
PR.AA-05	5.15, 5.18, 8.2, 8.3, 8.18	AC-01 peninjauan akses	R-01, R-02, K-01
PR.AA-01	5.15, 5.16, 5.18, 8.2, 8.5	Akun per orang	R-02, K-01
PR.AA-03	5.15, 5.16, 5.17, 5.18, 8.5	MFA akun vendor	R-01, K-01
ID.AM-02	5.9	Inventaris sistem	R-02
PR.PS-04	8.15, 8.17	Pencatatan aktivitas	R-01, K-01
DE.CM-03	7.4, 8.16	Tinjauan catatan	R-01, K-01
PR.DS-11	8.13	Cadangan lokasi terpisah	R-05, K-02
RC.RP-03	8.13	Uji pemulihan	R-05, K-02
RS.MA-01	5.26, 5.27, 5.28	Insiden bersama vendor	R-01, R-12, K-04, K-05
GV.SC-07	5.19, 5.20, 5.22, 5.31	Tinjauan vendor	R-01, R-08, K-05

Daftar Celah (Misalkan)

ID	Belum tercapai	Risiko	Pemilik risiko; tindakan	Bukti penerimaan
G-01	Belum lintas lokasi; 12 akun luput	R-01, K-01	Pemilik Medikara+; kepala operasi TI	120 dari 120 akun cocok
G-02	Catatan tidak ditinjau	R-01, K-01	Pemilik Medikara+; fungsi keamanan	Alarm uji ditangani
G-03	Pemulihan belum diuji	R-05, K-02	Pemilik layanan; kepala operasi TI	Hasil disahkan
G-04	Hak lokal beda; akun bersama	R-02, K-01	Pemilik SIMRS; pemilik layanan	Peran baku 5 rumah sakit
G-05	Vendor terlambat melapor	R-01, R-12, K-04, K-05	Pemilik Medikara+; pengelola vendor	Laporan dalam 12 jam
G-06	Inventaris belum direkonsiliasi	R-02	Pemilik SIMRS; kepala TI	Satu inventaris disetujui

Pembanding sementara: batas Bab 5, register Bab 3, dan SoA.

Keterlacakan Tiga Celah Prioritas



Kasus Medikara: Tiga Prioritas untuk Bab 8

PRADITA University

- Bab 5: R-11 keselamatan, R-01 insiden 2025 dan K-01, R-05 harapan kerugian terbesar.
- Tim memilih G-01, G-03, dan G-05. Varian uji kontrak Bab 3: vendor melapor setelah 30 jam.
- G-01: 120 akun dikali 6 menit, atau 144 jam per tahun; anggaran Rp60 juta pada Bab 5.
- G-03: 144 uji pemulihan dikali 3 jam, atau 432 jam per tahun.
- Total 576 jam, sekitar 3,6 bulan kerja dari 52 staf TI. Rincian kelangsungan menunggu Bab 10.

Aktivitas: Peran dan Langkah

PRADITA University

- Analis teknologi memimpin. Pemilik konteks memastikan bukti ada. Analis regulasi menandai kewajiban. Analis risiko menjaga tautan ke Bab 5.
- Tetapkan cakupan, lalu pilih subkategori pada keenam fungsi.
- Untuk Medikara: akses SIMRS, akun vendor, pencatatan *log*, dan cadangan data.
- Nilai status berdasarkan bukti, lalu terjemahkan menjadi celah terhadap Annex A.
- Hubungkan celah ke risiko dan kewajiban, lalu pilih tiga prioritas untuk Bab 8.

Aktivitas: Luaran, C2, dan Berkas

PRADITA University

- Luaran: profil saat ini, daftar celah, catatan SoA, dan tiga prioritas.
- Tonggak C2 Kondisi Saat Ini, ditinjau menjelang UTS.
- Rubrik: bukti 35 persen, status 25 persen, risiko 25 persen, batas kesimpulan 15 persen.
- Berkas di `sources/chapter06`: `profil-csf-saat-ini.csv`, `contoh-profil-medikara.csv`, `celah-kontrol.csv`, `pemetaan-csf-annex-a.csv`, `panduan-bukti.md`, `catatan-soa.md`.
- Data nyata wajib berizin dan dianonimkan. Pemeriksaan teknis hanya pada sistem berizin.

Ringkasan

- Kontrol dinilai dari kerahasiaan, integritas, ketersediaan, dan dampaknya pada pasien.
- ISMS menghubungkan risiko, kontrol, evaluasi, dan perbaikan melalui klausul 4 sampai 10.
- Annex A memberi 93 kontrol rujukan, dan SoA mencatat alasan serta pengecualian.
- Profil CSF menyampaikan hasil dan batas bukti. *Tier* bukan rata-rata status.
- Pemetaan menunjukkan kontribusi, bukan kesetaraan.

Latihan

1. Jelaskan mengapa organisasi dapat disertifikasi terhadap ISO/IEC 27001, tetapi tidak terhadap ISO/IEC 27002.
2. Fungsi Govern ditambahkan pada NIST CSF 2.0. Masalah organisasi apa yang ingin diselesaikan dengan penambahan itu?
3. Sebuah rumah sakit memutuskan tidak menerapkan satu kontrol Annex A. Apa yang harus ditulis di SoA agar keputusan itu dapat dipertanggungjawabkan?

Tabel contoh dan lembar isian tersedia pada modul.

Bacaan dan Pesan Utama

ISO/IEC 27001:2022, ISO/IEC 27002:2022, ISO 27799:2025
NIST CSF 2.0, NIST SP 1301, NIST SP 1302, CSF 2.0 Informative References
Ghafur dan rekan (2019), Culot dan rekan (2021)

Kesimpulan keamanan harus sepadan dengan cakupan buktinya.